

HW06-AI API Testing Report - EShop

Field	Value
Student	NGUYEN THIEN NHA TRAN
Student ID	23127272
Class	23KTPM2
Date	18/08/2026
SUT commit	85af3ba875c88283615e22cb108f13e2fccaf0e9
Local execution URL	http://127.0.0.1:3001

1. Revised scope

The student changed the group allocation on 18/08/2026 and selected member 1's row. The selection is confirmed unique within the group: no other member chose the same three APIs (FR-02 / FR-07 / FR-15).

Pool	Feature	Primary endpoint
A	FR-02 Login and account lockout	POST /api/login
B	FR-07 Add to shopping cart	POST /api/cart
C	FR-15 Create product	POST /api/products

GET /api/cart and GET /api/products/:id are used only as supporting state/persistence oracles. They are not counted as additional selected APIs.

2. Method and audit workflow

The reusable generator performs separate passes for contract variables, equivalence classes and boundaries, state transitions, SEC-01 through SEC-07, response schemas, minimum representative selection, audit, and extension. The artifacts keep three stages:

- test-cases-ai-original.json : 35 raw AI cases per API, initially marked INCOMPLETE .
- test-cases-ai-reviewed.json : preliminary reviewed AI-only catalog.
- test-cases.json : reviewed catalog plus five student-origin extensions per API.

The student reviewed and confirmed every verdict and adopted the extensions. Six extensions were strengthened during that review so the automated assertion matches the case intent: A-STU-036 now decodes the JWT and compares its role claim to the persisted role; A-STU-037 was repurposed from a duplicate secret check into a user-enumeration comparison; B-STU-036 now performs a real 2+3 sequence and asserts the merged total via a GET-cart callback; B-STU-037 provisions two users and asserts cart isolation; B-STU-038 reads the caller's cart back to prove ownership is not redirected; and C-STU-038 was repurposed from a near-duplicate category case into an id mass-assignment check. Expected results come from the README/specification. Observed buggy behavior is never used as the oracle.

3. Pool A - FR-02 login

The 40 cases cover email/password presence, null/blank/wrong types, malformed JSON, registered and unknown accounts, wrong credentials, generic errors, SQL injection, body role claims, JWT schema, secret absence, and the lockout state machine at one, two, and three consecutive failures.

Boundaries and states:

- Before three failures, a correct password must still work.
- At three failures, the account is locked for 30 seconds.
- A successful login resets the consecutive-failure counter.
- The exact expiry boundary remains manual because reliable automation requires a controllable clock or timed fixture.

Observed findings:

- BUG-01 : success returns plaintext password and internal account fields.
- BUG-02 : malformed/missing/wrong-type fields are not validated.
- BUG-04 : the failed-attempt counter advances too quickly; two failures already lock the account.

- Cross-cutting `BUG-03` : malformed JSON returns HTML instead of JSON.

Result: 40 designed, 39 executed, 19 passed, 20 failed, 1 not run.

4. Pool B - FR-07 add to cart

The suite covers JWT enforcement, product-ID partitions, positive-integer quantity boundaries, missing/forged name and price, malformed JSON, SQL/XSS-like strings, repeated product addition, different-product state, ownership/mass-assignment probes, and exact success/error schemas. Supporting `GET /api/cart` verifies post-state.

Observed findings:

- `BUG-05` : invalid IDs, quantities, names, and prices are accepted.
- `BUG-06` : adding the same product appends a duplicate row instead of increasing one row's quantity.
- `BUG-07` : the API trusts client-supplied name and price rather than canonical catalog data.
- Cross-cutting `BUG-03` : malformed JSON returns HTML instead of JSON.

Result: 40 designed/executed, 14 passed, 26 failed.

5. Pool C - FR-15 create product

The 40 cases cover missing/malformed/non-admin authentication; name lengths 1, 254, 255, and 256; missing/null/blank/wrong-type names; positive, zero, negative, string, boolean, array, and unsafe-integer prices; existing/stale/nonexistent categories; optional fields; SQL/XSS-like text; body role/id/owner fields; exact response schema; and read-after-write persistence.

Observed findings:

- `BUG-08` : `POST /api/products` performs no JWT or admin-role check.
- `BUG-09` : required name, positive price, and existing-category constraints are not enforced.
- Cross-cutting `BUG-03` : malformed JSON returns HTML instead of JSON.

Result: 40 designed/executed, 14 passed, 26 failed.

6. Security traceability

Requirement	Representative cases	Result
SEC-01 password protection	<code>A-AI-001</code> (secret exposure); <code>A-STU-037</code> (user enumeration)	Failed: plaintext password exposed in login response. Passed: unknown-email and wrong-password responses are indistinguishable
SEC-02 valid JWT	<code>B-AI-002..006</code> , <code>C-AI-002..005</code>	Cart protected; product creation unprotected
SEC-03 admin role	<code>A-AI-023</code> , <code>C-AI-005</code> , <code>C-STU-037</code>	Failed for product creation
SEC-04 safe handling of HTML	<code>B-AI-033</code> , <code>C-AI-034</code>	API keeps payload as JSON data; consuming UI still needs manual verification
SEC-05 parameterized queries	<code>A-AI-024..025</code> , <code>B-AI-032</code> , <code>C-AI-033</code>	Injection did not change query meaning
SEC-06 profile role update	N/A	Explicitly deferred: selected operations do not update profiles
SEC-07 OTP lifecycle	N/A	Explicitly deferred: selected operations do not issue or consume OTPs

7. Postman/Newman features

Used and evidenced: Collection v2.1, folders, collection/environment variables, bearer tokens, dynamic entity IDs, collection-level pre-request script, automatic `X-Student-Id` header, JSON and malformed raw bodies, sequential setup requests, JSON Schema assertions, cross-request state callbacks, and CLI/JSON/HTML Newman reporters.

Not claimed without student evidence: shared workspace, monitor, mock server, Postman Console screenshot, or data-file Runner execution.

8. Execution summary

Metric	Pool A	Pool B	Pool C	Total
Designed	40	40	40	120
AI-generated	35	35	35	105
Proposed student extensions	5	5	5	15
Executed	39	40	40	119
Passed	19	14	14	47
Failed	20	26	26	72
Not run	1	0	0	1

The clean Newman run executed 222 HTTP requests and 466 assertions. It recorded 124 failed assertions and zero request, pre-request, or test-script failures. Exit code 1 is expected because contract violations are retained. Evidence is in `reports/newman-cli.txt`, `newman-report.json`, and `newman-report.html`.

9. Bug reporting

Nine reproducible bug groups are drafted in `bug-reports.md`. GitHub Issue URLs and screenshots remain student actions. No publication or screenshot is claimed.

10. CI/CD

The manual workflow validates the catalog and generator, checks out an exact SUT commit (the student's fork by default), seeds and starts the backend, runs a CI Postman suite, and uploads Newman JSON/HTML plus the backend log even on failure. Input `evidence_mode` selects the suite: `green` runs 12 reviewed cases that pass on the SUT (job green), and `red` runs those 12 plus one real reviewed case `C-AI-002` (missing-JWT product creation) that genuinely fails on the SUT because of BUG-08 (job red, exactly one failing case). Both suites are built by `tools/build_ci_suites.py` from the reviewed catalog; no expected result is weakened and no assertion is fabricated. See `ci-cd-report.md` for the two run links and screenshots.

11. AI-driven generator

`skills/generate-eshop-api-tests/` contains the instructions, catalog validator, Postman builder, unit tests, template, and pipeline reference. Validation enforces three pools, at least 35 AI plus five student cases per API, EC coverage, domain/state/security/schema tags, SEC traceability or explicit disposition, audit labels, and response schemas.

The student-drawn diagram is `test-generator/23127272_HW06_test_generator_diagram.png` (editable source: `.excalidraw`), and the design pseudocode is `test-generator/pseudocode.md`.

12. Remaining student actions

- (Done) Reviewed and confirmed all audit verdicts and adopted/refined the 15 extensions.
- (Done) X-Student-Id: 23127272 evidenced in `reports/screenshots/bug-console/` (request headers) and `reports/newman-cli.txt` (pre-request console log).
- Execute the 30-second lockout-expiry case with a controlled/timed fixture.
- (Done) Published the nine bugs as GitHub Issues (#57-#65 on `ntntran09/eshop-sut`) with screenshots in `reports/screenshots/github-issues/`.
- Push and record the required green and deliberate-failure CI runs.
- (Done) Generator diagram drawn personally in Excalidraw.
- Regenerate final PDFs after completing the human-owned evidence.